

# Cybersecurity Project Report

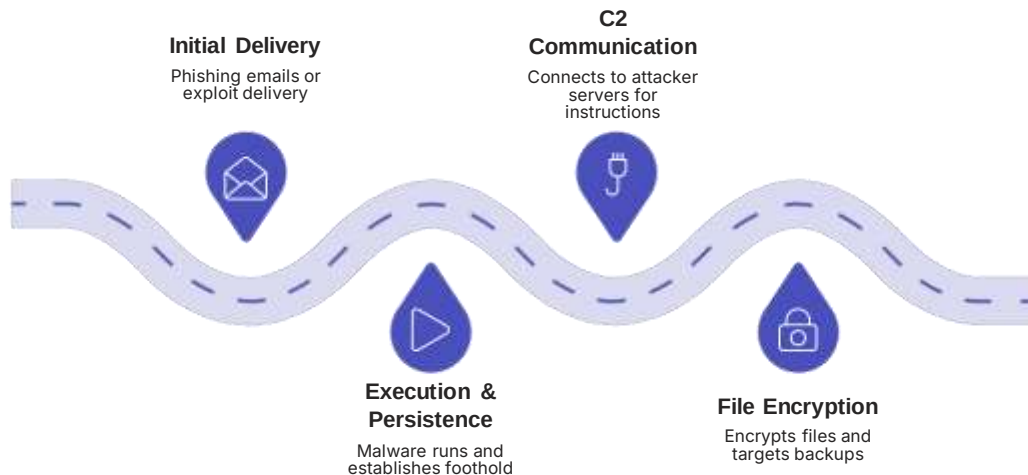
This document serves as a comprehensive theoretical overview of key cybersecurity concepts and attack vectors. Each section provides a description of the module topic along with illustrative diagrams and references drawn from authorized lab environments.



SECURITY RESEARCH

# Ransomware

Ransomware is a class of malware designed to deny access to a computer system or its data until a ransom is paid. Defending against it requires a multi-layered approach including robust backup strategies, EDR solutions, and user awareness training.



The lifecycle above illustrates how ransomware progresses from a simple phishing lure to full file encryption and extortion — underscoring why early detection at the delivery and execution stages is critical to preventing catastrophic data loss.

## Prevention Pillars

- Offline and immutable backups
- Endpoint Detection & Response (EDR)
- User awareness training
- Network segmentation

## Key Attack Vectors

- Phishing emails with malicious attachments
- Exploitation of unpatched vulnerabilities
- Remote Desktop Protocol (RDP) brute force
- Drive-by downloads from compromised sites

# Phishing Attacks

Phishing is a prevalent social engineering technique where attackers deceive individuals into revealing sensitive information such as login credentials or financial details. Attackers masquerade as trusted entities through email, SMS (Smishing), or voice calls (Vishing).

## Email Phishing

Fraudulent emails impersonating banks, IT departments, or executives to harvest credentials or deliver malware payloads.

## Smishing

SMS-based phishing that lures victims via text messages containing malicious links or urgent requests for personal data.

## Vishing

Voice call phishing where attackers impersonate support agents or authorities to extract sensitive information verbally.

## Red Flags in Phishing Emails



### Generic Greetings

"Dear Customer" instead of your actual name — a hallmark of mass-distributed phishing campaigns.



### Urgent or Threatening Language

Pressure tactics like "Your account will be suspended in 24 hours" designed to bypass rational thinking.



### Suspicious Sender Domains

Domains like support@paypa1.com that closely mimic legitimate addresses using typosquatting.



Defensive strategies include implementing **DMARC, SPF, and DKIM** email authentication protocols, deploying email filtering gateways, and conducting regular phishing simulation exercises to educate users.

# Google Dorks

Google Dorking, or Google hacking, utilizes advanced search operators to query the Google search engine for information not easily found through standard searches. Security researchers use these operators to uncover exposed sensitive files, misconfigured servers, or vulnerable web applications inadvertently indexed by search engines.



## Common Operators & Applications

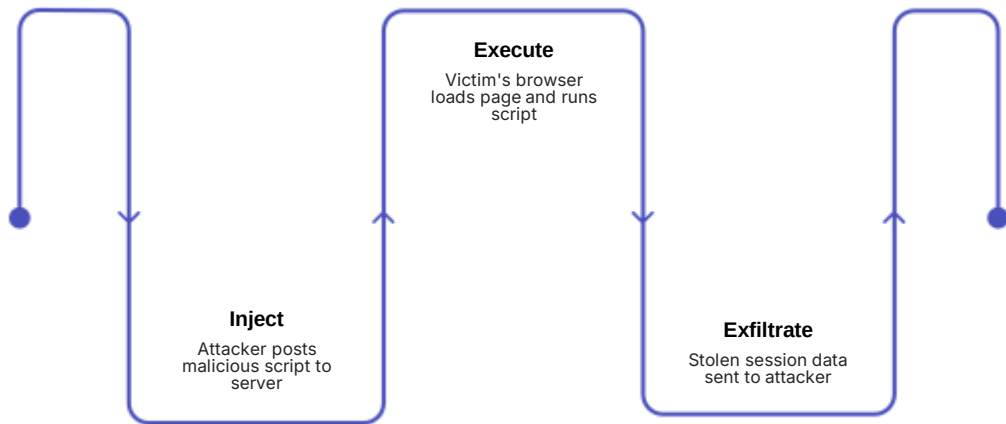
| Operator  | Syntax Example               | Security Use Case                        |
|-----------|------------------------------|------------------------------------------|
| site:     | site:example.com             | Map all indexed pages of a target domain |
| filetype: | filetype:pdf<br>confidential | Find exposed sensitive documents         |
| intitle:  | intitle:"index of"           | Discover open directory listings         |
| inurl:    | inurl:admin<br>login         | Locate exposed admin panels              |
| cache:    | cache:example.com            | View cached versions of pages            |



Google Dorking must only be performed on systems you own or have explicit written authorization to test. Unauthorized use may violate computer fraud laws.

# Web Application Attacks

Web application attacks target vulnerabilities inherent in web-based software, exploiting flaws in input validation, session management, or access controls. Two of the most prevalent attack types are Cross-Site Scripting (XSS) and Cross-Site Request Forgery (CSRF).



The diagram above illustrates how an XSS attack silently executes in a victim's browser — highlighting why server-side output encoding and Content Security Policy (CSP) headers are essential defenses.

## Cross-Site Scripting (XSS)

Malicious scripts are injected into trusted websites and executed in the victim's browser, enabling session hijacking, credential theft, or defacement.

## Cross-Site Request Forgery (CSRF)

Forces a logged-in user to unknowingly execute unwanted actions on a web application, exploiting the trust the site has in the user's browser.

## Mitigation Strategies

Secure coding practices, rigorous input sanitization, anti-CSRF tokens, and deploying Web Application Firewalls (WAF) form the core defense stack.

# SQL Injection & Security

SQL Injection (SQLi) is a critical vulnerability that occurs when an application improperly handles user-supplied data in backend database queries. This flaw can allow attackers to manipulate queries, enabling them to view, modify, or delete sensitive data — or even gain administrative control over the database server.

## ✗ Vulnerable Code (String Concatenation)

```
query = "SELECT * FROM users  
WHERE username = '"  
+ userInput + "'";  
  
// Attacker input:  
// ' OR '1'='1  
// Results in full table dump!
```

## ✓ Secure Code (Parameterized Query)

```
query = "SELECT * FROM users  
WHERE username = ?";  
  
stmt = conn.prepareStatement(query);  
stmt.setString(1, userInput);  
// Input treated as DATA, not code
```

### In-Band SQLi

The most common type — attacker uses the same channel to launch the attack and gather results, including error-based and union-based techniques.

### Blind SQLi

No data is returned directly. Attackers infer information by observing application behavior differences (Boolean-based or time-based delays).

### Primary Defense

Prepared statements (parameterized queries) treat all user input as data rather than executable SQL code, eliminating the injection vector entirely.

# Network Security — Nmap

Nmap (Network Mapper) is an industry-standard, open-source utility used for network discovery and security auditing. It operates by sending crafted packets to target hosts and analyzing responses to determine active devices, open ports, running services, and operating systems.

## Nmap Cheat Sheet Reference

A consolidated reference guide is essential for efficiently utilizing Nmap's extensive features. Below are the most critical flags used in security auditing engagements.

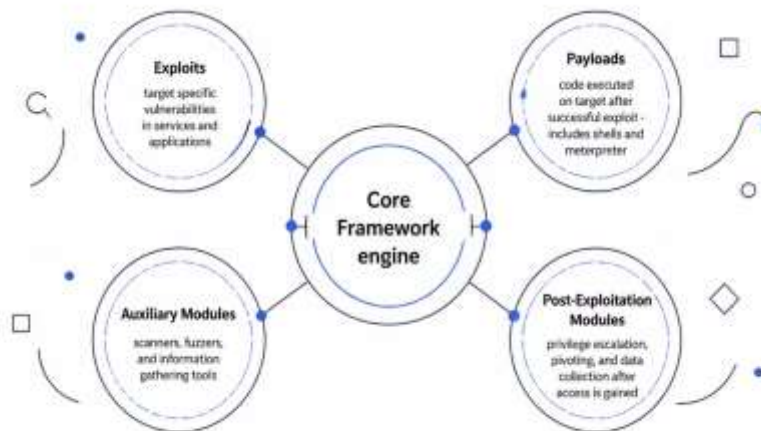
| Flag     | Scan Type         | Operational Purpose                                                              |
|----------|-------------------|----------------------------------------------------------------------------------|
| -sn      | Ping Scan         | Host discovery without port scanning — identifies live hosts on a subnet         |
| -sS      | SYN Scan          | Stealthy half-open scan; does not complete TCP handshake, reducing log footprint |
| -sV      | Version Detection | Probes open ports to determine service name and version number                   |
| -O       | OS Fingerprinting | Attempts to identify the operating system of the target host                     |
| -A       | Aggressive Scan   | Enables OS detection, version detection, script scanning, and traceroute         |
| -p-      | Full Port Scan    | Scans all 65,535 TCP ports rather than the default top 1,000                     |
| --script | NSE Scripts       | Runs Nmap Scripting Engine scripts for vulnerability detection and enumeration   |



Nmap is a foundational tool for network administrators to map their environments and identify potential unauthorized or vulnerable services. Always obtain written authorization before scanning any network.

# Metasploit Framework

The Metasploit Framework is a widely used penetration testing platform that provides infrastructure for testing, developing, and executing exploits against remote target machines. It is utilized by security professionals to validate vulnerabilities and assess the overall security posture of systems in authorized engagements.



## Framework Components

01

### Reconnaissance

Auxiliary scanner modules gather intelligence on target systems, open ports, and running services before exploitation.

02

### Exploitation

Exploit modules leverage known CVEs or logic flaws to gain initial access to the target system.



# CMS WordPress VAPT

Vulnerability Assessment and Penetration Testing (VAPT) for Content Management Systems like WordPress involves systematically analyzing the application for security weaknesses. This includes auditing the WordPress core, installed plugins, and active themes for known vulnerabilities, as well as checking for misconfigurations such as weak passwords or exposed configuration files.

1

## Core Audit

Verify WordPress core is updated to the latest stable release. Outdated core versions expose known CVEs that are trivially exploitable.

2

## Plugin Review

Enumerate all installed plugins and cross-reference against vulnerability databases (WPScan, NVD). Remove unused or abandoned plugins immediately.

3

## Theme Hardening

Audit active and inactive themes for malicious code, outdated dependencies, and insecure file inclusion patterns.

4

## Access Controls

Enforce strong password policies, disable XML-RPC if unused, restrict login attempts, and implement multi-factor authentication for admin accounts.

## Common Vulnerability Scanning Tools

- **WPScan** — WordPress-specific black-box vulnerability scanner
- **Nikto** — Web server scanner for dangerous files and misconfigurations
- **Burp Suite** — Intercepting proxy for manual web application testing
- **OWASP ZAP** — Open-source automated security testing tool

## Security Hardening Checklist

- ☒ Update WordPress core, plugins, and themes
- ☒ Change default admin username
- ☒ Implement Web Application Firewall (WAF)
- ☐ Enable two-factor authentication (2FA)
- ☒ Restrict wp-admin access by IP allowlist
- ☐ Disable file editing via dashboard
- ☐ Configure proper file permissions (755/644)



Regular VAPT engagements help ensure the WordPress platform remains secure against common web threats and maintains compliance with organizational security policies.